



trySearch

Technical Requirements Document

Complete website and evidence-backed AEO/GEO analytics platform

Document ID	TRD-TRYSEARCH-001
Version	1.0
Status	Engineering baseline and production specification
Date	13 August 2026
Owner	trySearch Engineering
Scope	Public website, authenticated product, APIs, data, integrations, PWA, operations
Source basis	Repository audit of the current trySearch workspace

Purpose

This document defines the complete target behavior, architecture, quality attributes, controls, and release criteria for trySearch. It also records the current implementation baseline so engineering work can be prioritized without presenting demo-only or synthetic outputs as measured customer data.

Classification: Internal engineering and product planning



1. Document control

This TRD is the authoritative engineering baseline for the complete trySearch website. Requirements use normative language: shall indicates a release obligation; should indicates a strong recommendation; may indicates an optional capability.

Version	Date	Author / owner	Change
1.0	13 Aug 2026	trySearch Engineering	Initial complete-website baseline and production specification

1.1 Status vocabulary

Status	Meaning
Implemented	A working code path is present in the audited repository.
Partial	A code path exists, but production hardening, completeness, or evidence semantics are unfinished.
Demo-only	The flow works, but values are deterministic/modelled and are not original provider measurements.
Required	No dependable production implementation is present; delivery is required by this TRD.

1.2 Priority vocabulary

- P0 — production blocker: security, privacy, data-truth, or deployment failure that must be closed before public launch.
- P1 — general availability requirement: required for a reliable customer release.
- P2 — important post-GA enhancement: improves scale, usability, or competitive depth.
- P3 — optional optimization: beneficial but not release-gating.

Audit boundary

The baseline is derived from the current repository, not from marketing assumptions. Current code remains the source of truth for implemented behavior; this TRD defines the target where code and production requirements diverge.

2. Document map

- 3 — Executive summary
- 4 — Product definition and scope
- 5 — Personas and core journeys
- 6 — Current implementation baseline
- 7 — Target architecture
- 8 — Data-source and metric contract
- 9 — Functional requirements
- 10 — API and integration requirements



- 11 — Data requirements
- 12 — Security and privacy requirements
- 13 — Non-functional requirements
- 14 — Deployment and operations
- 15 — Quality and test strategy
- 16 — Release plan
- 17 — Risk register and open decisions
- 18 — Production acceptance checklist
- Appendix A — API inventory
- Appendix B — Logical data model
- Appendix C — Environment variables
- Appendix D — Glossary and source basis

3. Executive summary

trySearch is a multi-surface AEO/GEO platform for measuring how a brand is exposed to AI-assisted discovery, identifying evidence gaps, and turning those gaps into content actions. The current codebase already provides a strong evidence-backed AI Search Analytics foundation: multi-page website crawling, Google Search Console reporting, Perplexity search/answer evidence, scheduled scan configuration, durable database jobs, and evidence-grounded opportunities.

The remaining website is not yet production-complete. Prompt Intelligence and Visibility Tracking still generate deterministic SHA-256-derived modelled values; Content Studio generates a local template; the master workspace seeds and aggregates those legacy results. Those paths may support demonstrations only and shall not be presented as original analytics.

Non-negotiable product rule

trySearch shall never present a fabricated, deterministic, inferred, or unavailable value as a measured AI-search result. Every customer metric must identify its source, scope, timestamp, denominator, and evidence status.

3.1 Production launch posture

The audited build is suitable for continued development and controlled demonstrations. It is not suitable for unrestricted production deployment until the following P0 issues are closed.



3.1 Production launch posture (continued)

Gate	Area	Required outcome
P0-1	Static file exposure	The repository-root catch-all can serve Python source, the SQLite database, hidden files, and deployment configuration.
P0-2	Contact PII exposure	GET /api/contacts is currently public and returns names, emails, messages, and timestamps.
P0-3	Admin stored XSS / authorization	Any signed-in user can access contact administration, and unescaped stored content is interpolated into HTML.
P0-4	Tracked runtime database	searchable.db is tracked by Git and currently modified; ignore rules alone do not remove it from history.
P0-5	Incomplete production topology	Render defines only the web service; PostgreSQL binding and a durable worker/scheduler are not provisioned.
P0-6	Synthetic analytics	Prompt Intelligence, Visibility Tracking, and master-workspace aggregates can expose modelled data as if it were observed.

4. Product definition and scope

4.1 Product goals

- Measure website readiness and real search/provider evidence without conflating unlike data sources.
- Enable a customer to configure one brand workspace, repeat a stable prompt cohort, and compare evidence over time.
- Connect verified first-party Google Search Console data to prompt and content decisions.
- Preserve original provider answers, ranked sources, request metadata, partial failures, and run configuration for verification.
- Turn evidence-backed gaps into prioritized, editable content work while keeping a human review step.
- Deliver a professional, responsive, accessible, installable web application across desktop and mobile platforms.

4.2 In scope

- Public marketing site, navigation, contact capture, authentication, profile, and account lifecycle.
- One-time master workspace onboarding and the linked workspace summary.
- AI Search Analytics: projects, crawl audit, GSC, prompt configuration, provider evidence, opportunities, scheduling, and export.



- Prompt Intelligence, AI Visibility Tracking, and Content Studio, migrated onto the shared evidence contract.
- Flask APIs, PostgreSQL data model, background jobs, external integrations, PWA/offline behavior, observability, deployment, and quality controls.

4.3 Out of scope for v1.0 GA

- Unapproved scraping of closed AI products or representation of provider web applications as official APIs.
- Guaranteed ranking in any AI system, search engine, or recommendation surface.
- Automatic external publication without an explicit CMS connector or recorded manual confirmation.
- Enterprise billing, advanced agency white-labelling, and custom data residency unless separately approved.
- Replacing source evidence with generic LLM opinions or synthetic benchmark scores.

4.4 Key assumptions and dependencies

- The production system uses PostgreSQL; SQLite remains a local development convenience only.
- Google Search Console provides standard first-party search performance; ordinary web rows shall not be relabelled as isolated AI Overview traffic.
- Perplexity is the currently implemented live provider for prompt evidence; unsupported providers must show not connected or planned.
- Provider APIs, pricing, quotas, regions, terms, and response shapes are external dependencies and require adapter-level monitoring.
- The target organization/RBAC model extends the current user-owned tenancy without weakening ownership checks.

5. Personas and core journeys

Persona	Primary needs	Success signal
Brand / growth lead	Understand where the brand appears, why it is absent, and what to do next.	Can verify every metric and export a prioritized action plan.
SEO / AEO specialist	Audit pages, manage prompt cohorts, compare competitors, and inspect source evidence.	Can reproduce metrics from saved evidence and compare like-for-like runs.
Content strategist	Convert evidence gaps into briefs, drafts, proof requirements, and review steps.	Every draft links to the prompt or source gap that justified it.
Agency operator	Manage multiple client domains without cross-tenant leakage.	Projects and evidence remain isolated, searchable, and auditable.
Administrator / operator	Control users, contacts, provider budgets, jobs, incidents, and data requests.	Role-protected operations and complete audit trails.

5.1 Core end-to-end journey

1. The user creates an account or signs in and is returned to the originally requested safe same-origin destination.



2. The user creates a brand workspace once, supplying website, industry, topic, goal, and competitor context.
3. trySearch creates linked product configuration without inventing initial measurements.
4. The user runs a bounded technical crawl and reviews page-level evidence and findings.
5. The user connects a verified Search Console property and synchronizes a documented date range.
6. The user creates topics, competitors, and active prompts, then runs a provider scan.
7. trySearch stores exact answers and sources, computes documented metrics, and displays partial/error states honestly.
8. The user turns evidence-backed opportunities into a content brief, edits the output, and records review/publication status.
9. Scheduled scans repeat the same cohort; comparable changes are shown and cohort changes are flagged.



6. Current implementation baseline

Surface	Baseline	Current capability / limitation
Public homepage	Partial	Responsive marketing UI, auth-aware links, animated example chart, feature cards, contact form, master setup, footer. Several provider claims and values remain illustrative.
Authentication / profile	Partial	Registration, login, logout, remembered cookie session, protected pages, read-only profile. No verified email, recovery, MFA, return path, roles, or full account lifecycle.
Master workspace	Partial	Atomic creation of linked modules and summary page. Existing submissions are silently reused; seeded prompt/visibility results are synthetic.
AI Search Analytics	Implemented / partial	Evidence-first workspace with multi-page crawl, GSC OAuth/sync, topics, competitors, prompts, schedules, Perplexity evidence, grounded opportunities, export, and job progress. Worker and production controls need hardening.
Prompt Intelligence	Demo-only	Complete collection/prompt workflow and history; scores and answers are deterministic SHA-derived results.
Visibility Tracking	Demo-only	Complete watchlist/scan/history UI; engine scores and appearances are deterministic SHA-derived baselines.
Content Studio	Partial	Persisted briefs, editable drafts, SEO fields, version/status, and local template generation; no evidence-carrying generation contract or CMS publication connector.
PWA / mobile	Partial	Standalone manifest, offline fallback, responsive layouts, reduced motion, and service worker. Icon set, update UX, cache resilience, and mobile accessibility need completion.
Operations / admin	Required	Health endpoint and basic Render/Gunicorn configuration exist. RBAC, secure contact admin, CI/CD, monitoring, backups, worker service, and production IaC are missing.

6.1 Implemented technology baseline

- Backend: Flask 3.1+, Gunicorn, SQLAlchemy Core 2.0+, Werkzeug password hashing.
- Data: PostgreSQL in production, SQLite fallback in development; 33 logical SQL tables in the current monolith.
- Frontend: server-served HTML, CSS, and vanilla JavaScript; native dialogs; SVG/DOM charts; responsive application shell.



- Integrations: public website HTTP crawl, Google OAuth/Search Console, Perplexity Search and Agent APIs, optional Hugging Face Inference Providers or Ollama-compatible chat completions for grounded actions.
- Hosting baseline: Render blueprint, Dockerfile, Procfile, health endpoint, and environment-variable configuration.
- Current automated coverage: five passing helper-level tests for crawl safety, URL canonicalization, unavailable values, Perplexity parsing, and evidence-reference validation.

Legacy boundary

server.py and server_mongo.py are legacy account/contact alternatives. They do not implement the complete analytics product and shall not be supported production endpoints.

7. Target architecture

Target production architecture

Evidence remains source-specific from collection through presentation.

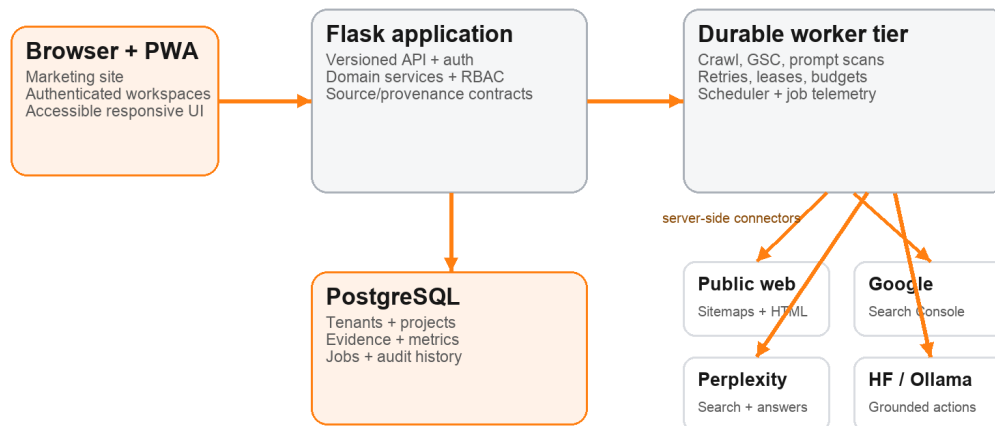


Figure 1 — Target production architecture. The current monolith is refactored behind the same product contract.



7.1 Component responsibilities

Component	Responsibilities
Web client / PWA	Render public and authenticated surfaces; accessible navigation; source-specific states; job progress; evidence inspection; export; offline shell without caching private API data.
Flask web service	Authentication, RBAC, validation, versioned JSON API, project ownership, OAuth initiation/callback, job enqueue, read models, security headers, and audit events.
Domain services	Crawl, GSC, prompt configuration, evidence normalization, metric calculation, content opportunities, retention, and deletion contracts.
Durable workers	Execute crawl/GSC/provider jobs outside Gunicorn; claim leases; retry with backoff; enforce idempotency, quotas, concurrency, cancellation, and telemetry.
Scheduler	Create one due run per project/window with calendar-aware timezone behavior and distributed locking.
PostgreSQL	Tenant/account data, configuration, source evidence, immutable run snapshots, jobs, audit history, retention metadata, and referential integrity.
Provider adapters	Isolate Google, Perplexity, Hugging Face, Ollama, and future supported providers; normalize errors and preserve provider identifiers without cross-source relabelling.
Observability	Structured logs, request/job correlation, metrics, traces, alerts, provider-cost telemetry, backup verification, and incident evidence.

7.2 Architectural constraints

- One supported production application endpoint and one versioned API contract.
- No network work, schema alteration, or long-running scan during module import or web request startup.
- All external credentials remain server-side and are supplied through environment-specific secret management.
- Background tasks are at-least-once and therefore idempotent; a job key may create at most one persisted scan result.
- Source evidence is immutable after completion; derived summaries may be recalculated with versioned algorithms.
- The UI may degrade when an external provider fails, but core account and stored-data access remains available.

8. Data-source and metric contract

Metric provenance contract

No source may be relabelled as another source, and unavailable data is never converted to zero.

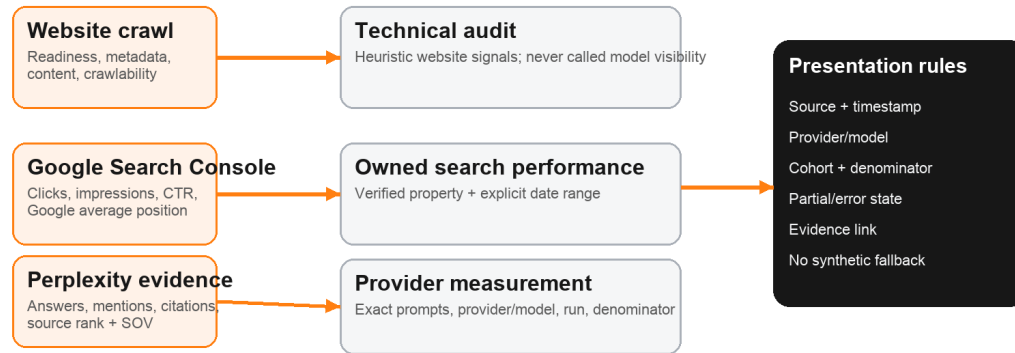


Figure 2 — Source-specific metric boundaries and presentation rules.



8.1 Required metric definitions

Metric	Source	Definition	Display rule
Website readiness	Website crawl	Documented aggregate of fetched-page metadata, content, crawlability, and structured-data checks.	Exclude unavailable pages; never label as provider visibility.
Answer visibility	Provider answers	Completed answers with <code>brand_mentioned=true</code> ÷ completed answers with answer text × 100.	Failed/empty answers excluded; display completed/prompt counts.
Citation rate	Provider answers	Completed answers whose citation annotations link to the tracked domain ÷ completed answers with answer text × 100.	No answer evidence means unavailable, not 0%.
Source presence	Provider search	Measured prompt searches containing the tracked domain in ranked results ÷ measured prompt searches × 100.	Provider and region must be displayed.
Average source position	Provider search	Arithmetic mean of <code>best_source_rank</code> across appearances only.	Absent prompts excluded and shown separately; no rank K+1 substitution.
Share of voice	Provider answers	Client brand presence ÷ client plus configured competitor presence for the saved competitor snapshot.	Unavailable when no competitors or denominator is zero.
GSC CTR	Google Search Console	Clicks ÷ impressions × 100 for the selected property/date range and saved rows.	Label row limit/truncation and do not call AI Overview CTR.
GSC average position	Google Search Console	Impression-weighted Google Search position for the selected property/date range.	Keep separate from provider source rank.

8.2 Provenance fields

- Source type; provider and returned model where applicable; region/locale; exact timestamp; run/job identifier.
- Project, property, page set, prompt cohort, active prompt count, competitor snapshot, and date range.
- Completed, partial, failed, unavailable, and stale status with the failure class and last successful timestamp.
- Numerator and denominator or appearance count; metric algorithm version; evidence/detail link.
- Provider request IDs, latency, normalized sources, raw response retention state, and export generation time.

8.3 Comparability rules

- Trend deltas shall compare the same source, provider/model, region, prompt cohort, competitor snapshot, and metric algorithm version.
- When any comparison dimension changes, the UI shall start a new baseline or label the delta non-comparable.



- Provider outage and missing evidence shall not lower a metric; the run is partial or unavailable.
- Marketing examples shall be labelled illustrative and shall never display Live unless backed by a recent source sync.

9. Functional requirements

9.1 Platform, navigation, and account

ID	Pri	Requirement	Verification / acceptance
FR-NAV-001	P1	The system shall provide one branded navigation model across public and authenticated pages, with visible and programmatic active state.	All destinations are reachable at 320 px; active links expose aria-current; no unintended page-level horizontal scroll.
FR-NAV-002	P1	Authenticated pages shall use a responsive application shell with an accessible drawer or rail, keyboard focus management, and safe-area support.	Drawer traps focus, closes on Escape/scrim, restores focus, marks background inert, and preserves 44 x 44 px controls.
FR-AUTH-001	P0	Protected destinations shall preserve and validate a same-origin return path through login.	Requesting /analytics while signed out returns to /analytics after login; external or malformed next values are rejected.
FR-AUTH-002	P0	Registration and login shall enforce normalized identity, password policy, rate limiting, anti-enumeration, session rotation, and accessible validation.	Security/API tests cover duplicate identity, brute force, fixation, generic errors, labels, live validation, and lock/backoff behavior.
FR-AUTH-003	P1	The account lifecycle shall include email verification, password reset, active-session revocation, account export, and verified deletion.	End-to-end tests complete each flow; deletion finishes within the privacy SLA and cascades owned data.
FR-AUTH-004	P2	The platform should support optional MFA and organization membership with owner, admin, analyst, editor, and viewer roles.	Role matrix tests prove least privilege and prevent cross-tenant IDOR.
FR-PROF-001	P1	Profile shall show account data, workspace membership, integration status, data export/deletion controls, and logout.	User can review and action each item without exposing secrets or another tenant's data.



9.2 Public website, contact, and administration

ID	Pri	Requirement	Verification / acceptance
FR-HOME-001	P0	Public feature claims and provider labels shall reflect configured production integrations.	Unsupported providers are omitted or marked planned; no measured claim appears without stored evidence.
FR-HOME-002	P0	Illustrative homepage metrics and animations shall be explicitly labelled as example data.	Hero chart/provider cards say Example dashboard; Live appears only for current evidence-backed data.
FR-HOME-003	P1	The homepage shall include complete discoverability metadata and machine-readable product identity.	Unique description, canonical, Open Graph/Twitter, Organization/Website/Product JSON-LD, sitemap inclusion, and valid robots directives pass validation.
FR-HOME-004	P1	Desktop and mobile authentication CTAs shall behave consistently.	Signed-out CTA opens login; signed-in CTA opens the approved default workspace destination on both navigation variants.
FR-CONTACT-001	P0	Public contact submission shall accept POST only, validate lengths/email, record consent context, rate-limit abuse, and announce success/error accessibly.	Invalid/oversized/spam requests are rejected; valid records store minimum required data and a documented retention date.
FR-CONTACT-002	P0	Contact listing/export shall be restricted to authorized administrators and render stored values as escaped text.	Anonymous/non-admin requests return 401/403; XSS payloads do not execute; CSV matches visible authorized rows.
FR-ADMIN-001	P1	Administrative actions shall be role-gated, audited, and separated from customer-facing APIs.	Every privileged read/write records actor, action, target, outcome, timestamp, and request ID.



9.3 Master workspace

ID	Pri	Requirement	Verification / acceptance
FR-MASTER-001	P1	One submitted brand brief shall atomically create linked Analytics, Visibility, Prompt, and Content starting points.	All records commit together or none commit; no orphan remains after an injected stage failure.
FR-MASTER-002	P1	Existing-workspace behavior shall be explicit: open, update, or intentionally replace.	New form values are never silently ignored; replacement requires confirmation and applies a documented data policy.
FR-MASTER-003	P0	Workspace creation shall not fabricate initial visibility, citation, rank, sentiment, or competitor measurements.	New summary metrics are unavailable until an approved source completes; synthetic generators are disabled in production.
FR-MASTER-004	P1	Aggregate cards shall display source, provider/model where applicable, freshness, cohort/date range, and status.	Every non-null metric links to its source report and shows a last-success timestamp.
FR-MASTER-005	P2	The user should be able to update brand aliases, domain, industry, topic, goals, and default region without losing history.	Configuration is versioned; affected future scans use the new version; prior runs retain snapshots.



9.4 AI Search Analytics

ID	Pri	Requirement	Verification / acceptance
FR-ANA-001	P1	Users shall create, select, update, and remove owned website projects using an exact HTTP(S) seed URL and normalized domain.	Validation preserves safe public paths; deletion confirms scope and cascades only the owner's linked data.
FR-ANA-002	P1	A full audit shall crawl a bounded same-site set discovered from robots, sitemap indexes/sitemaps, and internal links.	Async job reports discovered/selected/fetched/failed counts, progress, per-page status, and sitemap provenance.
FR-ANA-003	P0	Crawl-derived readiness shall remain separate from provider visibility and shall use nullable unavailable semantics.	No crawl value is labelled AI visibility/citation/SOV; failed fetches are unavailable rather than measured zero.
FR-ANA-004	P1	The crawl shall capture status, final URL, title, description, headings, visible words, language, canonical, noindex, internal/external links, and validated structured data.	Saved page record and findings reproduce the displayed audit; invalid JSON-LD and canonical targets are reported.
FR-ANA-005	P1	Users shall connect, select, synchronize, and disconnect a read-only Google Search Console property.	OAuth, token refresh/revoke, property permissions, date range, freshness, partial/error, and row-cap states pass contract tests.
FR-ANA-006	P1	Search Console shall report clicks, impressions, CTR, Google average position, query, page, property, and date range without AI Overview relabelling.	Metrics reconcile with saved rows; truncation is disclosed; source badge states Google Search Console.
FR-ANA-007	P1	Users shall manage topics, competitors, prompts, prompt intent, active state, region, and daily/weekly/monthly schedule.	Each run stores exact prompt and competitor snapshots; limits and costs are shown before enqueue.



9.4 AI Search Analytics (continued)

ID	Pri	Requirement	Verification / acceptance
FR-ANA-008	P0	Provider scans shall save original evidence for every attempted prompt.	Record includes exact prompt, provider/model, request IDs, answer, normalized sources/ranks, timestamps, latency, status, error, and raw-response retention state.
FR-ANA-009	P0	Provider metrics shall be reproducible from stored evidence and documented denominators.	Independent test recomputes mention, citation, source presence, average rank, and SOV within rounding tolerance.
FR-ANA-010	P1	The evidence UI shall support provider/topic/status/run filtering and safe source navigation.	Links are validated HTTP(S), open with noopener/noreferrer, and detail view exposes provenance plus preserved answer/source text.
FR-ANA-011	P1	Evidence-grounded opportunities shall cite valid stored evidence references and shall not alter measured metrics.	Unsupported model output is rejected; deterministic grounded fallback is available; each action opens its evidence.
FR-ANA-012	P1	Scans shall expose queued, running, succeeded, partial, failed, cancelled, and stale/retry states.	Progress is announced accessibly; repeat clicks are idempotent; the last successful report remains available during failure.
FR-ANA-013	P1	Export shall preserve source definitions, configurations, evidence, failures, run identifiers, provider/model, and generation timestamp.	JSON export round-trips required fields; UTF-8 CSV/ZIP export is added for tabular evidence and pages.
FR-ANA-014	P2	Trend comparisons should enforce cohort compatibility and explain non-comparable changes.	Provider/model/region/prompts/competitors/algorithm mismatch starts a new baseline or displays a clear warning.



9.5 Prompt Intelligence

ID	Pri	Requirement	Verification / acceptance
FR-PRM-001	P0	Prompt Intelligence shall replace deterministic SHA-derived measurements with the shared provider-evidence pipeline.	Production code returns no generated score without stored provider evidence; demo mode is isolated and labelled.
FR-PRM-002	P1	Users shall CRUD collections and prompts and filter by topic, provider, intent, active state, and evidence state.	Ownership tests pass; filtering is keyboard accessible; deleted configuration does not erase immutable historical snapshots.
FR-PRM-003	P1	Prompt research shall propose prompts with a recorded generation source and require user approval before measurement.	Proposed prompts remain distinct from active prompts; provider/model or ruleset is displayed.
FR-PRM-004	P1	Repeated prompt scans shall retain comparable history, provider evidence, and configuration snapshots.	No scan overwrites prior evidence; history displays baseline breaks when configuration changes.
FR-PRM-005	P2	Bulk import/export and duplicate detection should support agency-scale prompt operations.	Validated CSV import reports row errors without partial silent loss; canonical duplicates are flagged before activation.



9.6 AI Visibility Tracking

ID	Pri	Requirement	Verification / acceptance
FR-VIS-001	P0	Visibility Tracking shall use the shared evidence store rather than deterministic SHA-derived watchlist scores.	Every appearance traces to a provider answer/source and exposes provider/model, prompt, brand/competitor match, locale, and time.
FR-VIS-002	P1	Users shall CRUD watchlists with brand aliases, topic, competitor set, provider set, region, and cadence.	Configuration is validated, versioned, tenant-bound, and snapshotted into each run.
FR-VIS-003	P1	Tracking shall report answer visibility, citation, source presence/rank, SOV, and evidence-linked appearances using section 8 definitions.	Metrics reconcile to evidence and unavailable values remain null.
FR-VIS-004	P1	Trend comparisons shall use identical cohorts or be labelled non-comparable.	Automated tests cover provider, model, prompt, competitor, region, and algorithm changes.
FR-VIS-005	P2	Alerts should notify users of material evidence-backed changes without overstating provider certainty.	Threshold, cooldown, channel, source, comparison cohort, and opt-out are stored and displayed.

9.7 Content Studio

ID	Pri	Requirement	Verification / acceptance
FR-CONT-001	P1	Users shall create, edit, save, status, version, and delete owned content documents.	Unsaved changes are protected on document switch, generation, navigation, and refresh; ownership tests pass.
FR-CONT-002	P1	Generated drafts shall identify local template versus configured model, provider/model, generation time, and brief version.	Generation metadata is visible; failures preserve prior edits; no generated factual claim is marked verified automatically.
FR-CONT-003	P1	Analytics opportunities shall carry prompt/source evidence, topics, competitor gaps, and proof requirements into a content brief.	Each evidence-backed section links to the originating stored evidence and includes a human-review checklist.
FR-CONT-004	P1	SEO title, meta description, outline, document content, recommendations, and status shall be independently editable and versioned.	Concurrent update policy prevents silent overwrite; version history can restore a prior draft.
FR-CONT-005	P1	Published status shall require a recorded URL/manual confirmation or successful connected CMS action.	Status cannot imply external publication without evidence; connector errors remain visible.
FR-CONT-006	P2	The studio should support collaboration comments, assignments, approval state, and export to common formats.	Role permissions and attribution are preserved in document history and exports.



9.8 Responsive web and PWA

ID	Pri	Requirement	Verification / acceptance
FR-PWA-001	P1	The web application shall be installable with valid 192 × 192 and 512 × 512 regular and maskable icons.	Chrome/Edge/Safari installability checks pass and installed branding uses approved trySearch assets.
FR-PWA-002	P1	The service worker shall cache only an allowlisted public shell and provide an explicit update lifecycle.	Missing optional asset does not abort installation; new versions activate predictably; private/API responses are never cached.
FR-PWA-003	P1	Offline navigation shall show a branded fallback and explain which live features require reconnection.	Offline E2E test reaches fallback; cached shell loads; mutations and stale analytics are not misrepresented as current.
FR-MOB-001	P1	All core customer flows shall operate at 320, 360, 390, 430, 768, 1024, 1280, 1440, and 1920 CSS pixels.	No unintended horizontal page scroll; controls remain readable/operable; wide data has an accessible scroller or compact alternative.
FR-MOTION-001	P1	Decorative motion and WebGL shall respect reduced motion, Save-Data, device capability, visibility, and mobile composition.	No unnecessary WebGL startup under constrained conditions; CDN failure never blocks content or actions.



10. API and integration requirements

ID	Pri	Requirement	Verification / acceptance
API-001	P1	All supported product APIs shall be versioned under /api/v1 and described by a validated OpenAPI specification.	CI validates paths, schemas, auth, errors, nullable semantics, pagination, examples, and deprecation metadata.
API-002	P1	API errors shall use one machine-readable envelope with code, message, request_id, retryable flag, and field errors where applicable.	Contract tests cover 400, 401, 403, 404, 409, 422, 429, 502, and 503 responses.
API-003	P1	Create/enqueue operations shall support idempotency keys and safe retry behavior.	Replaying the same key and payload returns the original result; mismatched payload returns conflict.
API-004	P1	Unbounded list responses shall use cursor pagination, deterministic ordering, filter validation, and a documented maximum page size.	Pages/evidence/queries remain responsive on large datasets and return next_cursor.
API-005	P1	All resource operations shall authorize tenant and object ownership server-side rather than trusting client identifiers.	Cross-tenant IDOR tests return 404/403 for every resource family.
API-006	P2	Breaking API changes shall follow a deprecation window and migration note.	Clients receive documented sunset metadata and compatibility tests remain green until removal.
INT-GSC-001	P0	Google OAuth shall remain server-side, read-only, state-validated, tenant-bound, and encrypted at rest.	State/PKCE, refresh, revoke, denied consent, expired token, reconnect, and property-ownership tests pass.



10. API and integration requirements (continued)

ID	Pri	Requirement	Verification / acceptance
INT-GSC-002	P1	GSC synchronization shall run as a durable paginated/incremental job rather than a long HTTP request.	Enqueue responds within 2 seconds; retries avoid duplicate rows; progress and row cap are visible.
INT-PPLX-001	P0	Perplexity Search and Agent credentials shall remain server-side and responses shall be normalized without losing raw provenance.	No secret appears in HTML/JS/logs; adapter contract tests cover success, partial, malformed, timeout, 429, and provider 5xx.
INT-LLM-001	P1	Hugging Face/Ollama assistance shall be limited to evidence-grounded categorization and actions, not visibility measurement.	Every accepted action cites supplied evidence IDs; unsupported output is rejected and logged without altering metrics.
INT-EXT-001	P1	Every provider adapter shall implement timeout, bounded retry/backoff, circuit breaking, quota/cost recording, and normalized failure classes.	Fault-injection tests prove first-party UI remains usable during provider failure.



11. Data requirements

ID	Pri	Requirement	Verification / acceptance
DATA-001	P0	The schema shall use versioned Alembic migrations; application import shall not mutate production schema.	Clean install and upgrade from the audited schema reach head; rollback/runbook and migration tests preserve records.
DATA-002	P0	Logical relationships shall use foreign keys, uniqueness constraints, indexes, and explicit deletion rules.	Orphan audit returns zero; cascade/restrict behavior matches privacy and immutable-evidence policy.
DATA-003	P1	All timestamps shall be timezone-aware UTC at rest and rendered in the user's locale/timezone.	Serialization includes offset/Z; schedule and DST tests pass.
DATA-004	P0	Synthetic or legacy compatibility rows shall be isolated from production-visible measured reports.	Static/API tests prove no SHA/random/template score is returned as measured; unavailable data remains null.
DATA-005	P1	Source evidence shall retain immutable prompt/configuration snapshots and a versioned metric algorithm identifier.	Recalculation can reproduce both original and current derived metrics without mutating raw evidence.
DATA-006	P1	Raw provider payload, normalized source, analytics history, GSC, contact, token, and log retention shall be configurable and documented.	Scheduled retention job deletes/aggregates expired data and records deletion outcomes.
DATA-007	P1	User/project export and deletion shall cover all owned tables and external token revocation.	Completeness reconciliation confirms exported/deleted counts across every related entity.



11. Data requirements (continued)

ID	Pri	Requirement	Verification / acceptance
DATA-008	P1	Sensitive values shall be encrypted in transit and at rest with documented rotation procedures.	TLS is enforced; OAuth tokens use stable managed keys; rotation rehearsal succeeds without plaintext exposure.
DATA-009	P2	Large evidence and raw-response data should use compression or object storage with integrity metadata.	Database size and query performance stay within thresholds; object checksums and access controls are verified.



11.1 Suggested retention baseline

Data class	Default	Notes
Raw provider payloads	90 days	Shorter by customer policy; normalized evidence may outlive raw payload.
Normalized analytics/history	13 months	Supports annual comparison; tenant contract may override.
GSC query rows	16 months maximum	Align with available reporting needs and Google/user policy.
Operational logs	30 days	Security/audit logs may require a separately approved longer period.
OAuth tokens	Until disconnect/revoke	Delete immediately on disconnect or account deletion.
Contact submissions	90 days or business-approved	Store minimum data and consent context; admin-only access.



12. Security and privacy requirements

ID	Pri	Requirement	Verification / acceptance
SEC-001	P0	Only allowlisted public assets shall be served from a dedicated static directory.	Requests for .env, .git, databases, Python, migrations, tests, and deployment files return 404/403 in production.
SEC-002	P0	Session-authenticated mutations shall require CSRF protection and same-origin validation.	Missing/invalid token fails; valid token succeeds; OAuth callbacks retain state validation.
SEC-003	P0	Endpoint-specific rate limits and account/provider budgets shall protect auth, contacts, crawls, GSC, and paid scans.	Abuse tests receive 429 with retry metadata; configured per-user/tenant limits cannot be exceeded.
SEC-004	P0	Contact and administrative data shall require explicit RBAC and output escaping.	Anonymous/ordinary users cannot list contacts; stored script strings render inert; privileged access is audited.
SEC-005	P0	Crawler networking shall resist SSRF, DNS rebinding, redirect pivots, private/link-local/metadata IPs, and non-standard ports.	Automated tests cannot reach loopback, RFC1918, link-local, IPv6 private, metadata, or rebind targets.
SEC-006	P1	Production responses shall enforce CSP, HSTS, frame protection, MIME protection, referrer policy, permissions policy, secure cookies, and trusted host/proxy handling.	Header tests pass on HTML/API responses and CDN/self-hosted assets comply with CSP.
SEC-007	P1	Secrets shall use environment-specific secret management, rotation, access logging, and log redaction.	Secrets scan is clean; tokens/connection strings never appear in client bundles, source, exception pages, or logs.



12. Security and privacy requirements (continued)

ID	Pri	Requirement	Verification / acceptance
SEC-008	P1	User inputs and provider content shall be length-limited, encoded, and safely rendered.	Stored/reflected XSS, CSV injection, URL scheme, HTML injection, and oversized-payload tests pass.
SEC-009	P1	Authentication shall support session revocation, inactivity/absolute expiry, password reset, and incident lockout controls.	Security tests cover stolen-cookie revocation, reset token expiry/single use, and account recovery.
SEC-010	P1	Production releases shall pass SAST, dependency, container, secret, and DAST checks with no known exploitable critical/high issue.	CI blocks on the security gate or records an approved, time-bound exception.
PRIV-001	P1	Privacy notices shall disclose crawl behavior, GSC access, provider processing, retention, and customer controls.	Consent and policy links appear before connection/submission; provider subprocessors are documented.
PRIV-002	P1	Verified access, correction, export, deletion, and integration-revocation requests shall be operationally supported.	Deletion completes within 30 days and produces an auditable completion record without retaining revoked tokens.



13. Non-functional requirements

ID	Category	Target / acceptance
NFR-REL-001	Availability	First-party application/API monthly availability $\geq 99.9\%$, excluding planned maintenance; provider degradation reported separately.
NFR-PERF-001	API latency	Authenticated read API p95 ≤ 500 ms and p99 ≤ 2 s; mutation/job-enqueue p95 ≤ 750 ms, excluding asynchronous execution.
NFR-JOB-001	Job timeliness	On-demand jobs start within 2 minutes at p95; scheduled jobs start within 15 minutes; completed results appear within 60 seconds.
NFR-ERR-001	Error rate	First-party 5xx rate $< 1\%$ over a rolling 30-day window; provider errors classified independently.
NFR-WEB-001	Core Web Vitals	Mobile p75: LCP ≤ 2.5 s, INP ≤ 200 ms, CLS ≤ 0.1 on representative public and authenticated routes.
NFR-UX-001	Responsive	All core flows work from 320 px to 2560 px; touch controls $\geq 44 \times 44$ CSS px on coarse pointers.
NFR-A11Y-001	Accessibility	WCAG 2.2 AA; keyboard complete; APG tablist/dialog/drawer behavior; visible focus; 200% zoom; status/error announcements.

13. Non-functional requirements (continued)

ID	Category	Target / acceptance
NFR-BR-001	Browsers	Current and previous major Chrome, Edge, Firefox, and Safari; required fallbacks for dialog, 100dvh, overflow, replaceAll, and Array.at.
NFR-SCALE-001	Scale	Horizontal web/worker scaling without duplicate schedules or cross-worker in-memory coordination; bounded tenant/provider concurrency.
NFR-DR-001	Recovery	Initial RPO $\leq$ 24 hours and RTO $\leq$ 4 hours; encrypted backups and quarterly restore verification.
NFR-OBS-001	Observability	Every request/job carries correlation IDs; metrics/logs/traces cover web, queue, database, providers, OAuth, cost, and backups.
NFR-MAINT-001	Maintainability	Critical backend modules $\geq$ 90% branch coverage and overall server $\geq$ 80%; typed/linted modular services and reviewed migrations.
NFR-I18N-001	Locale/time	Storage uses UTC; UI renders locale-aware dates/numbers; schedules are timezone and DST aware; UTF-8 supported end to end.

13.1 Accessibility-specific acceptance

- Tablists implement arrow, Home, End, Enter/Space, aria-selected, roving tabindex, and labelled panel relationships.
- Dialogs and navigation drawers trap focus, restore the invoking control, and prevent background interaction.
- Job progress and asynchronous success/failure use non-disruptive live regions; errors link to invalid fields.
- Charts provide equivalent text/table data; status is never conveyed by color alone; contrast passes AA.
- Wide tables expose an operable labelled scroller or compact detail pattern on narrow screens.

14. Deployment and operations



14.1 Required environment topology

Environment	Topology	Data/provider policy	Baseline
Local	Flask dev server, SQLite, optional local Ollama	Provider credentials optional; developer-owned test data	Implemented
Test / CI	Ephemeral PostgreSQL, web app, worker, browser runner	Mock OAuth/provider calls; no paid live requests	Required
Staging	Production-equivalent web, worker, scheduler, PostgreSQL	Isolated secrets, restricted OAuth client, capped provider budgets	Required
Production	Gunicorn web, managed PostgreSQL, durable queue workers, scheduler/cron, backups, monitoring	Secret-managed integrations, tenant quotas, retention jobs	Partial
Disaster recovery	Immutable application build plus verified backup restore	Secrets restored through secret manager	Required



14.2 Operational requirements

ID	Pri	Requirement	Verification / acceptance
OPS-001	P0	Production infrastructure shall provision web, managed PostgreSQL, durable worker/queue, scheduler, backups, and monitoring.	Infrastructure definition deploys all components; DATABASE_URL and stable encryption/database identity settings are bound correctly.
OPS-002	P1	Liveness and readiness shall be separate and expose no unnecessary database identity or secret context.	Liveness checks process; readiness checks database/queue dependencies; provider state is reported separately.
OPS-003	P1	The container shall run as a non-root user, copy only required artifacts, include a health check, and use a .dockerignore.	Image contains no .git, local DB, .env, tests, or unnecessary large assets; scanner and runtime tests pass.
OPS-004	P1	Python/runtime and dependencies shall be pinned and reproducible across local, CI, Docker, and Render.	Lock/hashes and runtime version produce one immutable artifact; automated updates run with tests.
OPS-005	P1	Structured logs shall redact secrets and include request_id, user/tenant where permitted, project, job, provider, outcome, and duration.	Automated redaction test covers OAuth/API keys, DATABASE_URL, email, raw answers, and configured prompt privacy.
OPS-006	P1	Operational dashboards and alerts shall cover HTTP health, queue depth/age, job/provider success and latency, spend, DB pool, OAuth refresh, and backup status.	Test alerts route correctly and each alert links to a runbook.
OPS-007	P1	Backups, restore, rollback, incident response, secret rotation, provider outage, and data deletion shall have tested runbooks.	Quarterly exercise meets RPO/RTO and records evidence, owners, gaps, and remediation.



14.2 Operational requirements (continued)

ID	Pri	Requirement	Verification / acceptance
OPS-008	P1	Jobs shall support leases, heartbeat, bounded retry/backoff, cancellation, dead-letter state, idempotency, and cost quotas.	Worker-restart/concurrency tests produce one final result and no lost job.
OPS-009	P1	Calendar-aware schedules shall use user timezone and distributed locking.	Concurrent schedulers create at most one due job per project/window; DST/month boundary cases pass.
OPS-010	P2	Static third-party libraries should be self-hosted or controlled by an approved dependency/CSP policy.	Three.js and other runtime assets load under CSP and remain available without an uncontrolled CDN dependency.



15. Quality and test strategy

Layer	Required coverage
Unit	URL/DNS safety; crawl/parser/sitemap edge cases; scoring; metric denominators; schedule/timezone; retention; evidence reference validation.
Database integration	PostgreSQL migrations, foreign keys, uniqueness/indexes, tenant isolation, transactional delete, concurrent claiming, idempotency, retention.
API integration	Auth lifecycle, CSRF, rate limits, RBAC, contact privacy, ownership/IDOR, validation, pagination, error envelope, export.
Provider contract	Google OAuth/refresh/GSC pagination; Perplexity success/partial/error/malformed; HF/Ollama malformed grounding; timeouts, quotas, retries.
End to end	Register/login/return path; master setup; audit lifecycle; GSC; prompt scan/evidence; content handoff; export; mobile navigation; offline/update.
Security	Sensitive-path enumeration, SSRF/rebinding, XSS, CSRF, fixation, brute force, IDOR, secret/dependency/container scans, DAST.
Accessibility	Automated axe plus keyboard, screen reader, high contrast, reduced motion, 200% zoom, and responsive data-table review.
Performance/resilience	Dashboard load, crawl bounds, concurrent jobs, provider outage, worker restart, database failover, queue recovery, backup restore.

ID	Pri	Requirement	Verification / acceptance
TEST-001	P0	CI shall run on every change and block merge on formatting/lint, unit, PostgreSQL integration, API, frontend/E2E, accessibility, and security gates.	A failing stage blocks merge; provider calls are mocked; artifacts and coverage reports are retained.
TEST-002	P0	CI shall include regression tests for every P0 finding in section 3.1.	Sensitive files/contacts/admin/synthetic metrics/deployment topology each have an automated gate.
TEST-003	P1	Provider contracts shall use captured sanitized fixtures and adapter-level schema validation.	Fixture suite covers current and legacy provider shapes without storing credentials or customer data.
TEST-004	P1	Migration rehearsals shall run against a production-like database clone before release.	Pre/post row counts, constraints, performance, rollback decision, and backup checkpoint are recorded.
TEST-005	P1	Release candidates shall pass staging smoke tests and a documented production-readiness checklist.	Core journeys, integrations, worker, alerts, backups, and rollback are signed off by named owners.



ID	Pri	Requirement	Verification / acceptance
TEST-006	P1	Metric correctness shall be tested from raw evidence fixtures independently of presentation code.	Expected numerator/denominator, null, partial, rank, SOV, and comparison cases pass.

15.1 Current test baseline

At audit time, five unittest cases pass. They cover private/non-standard URL rejection, same-site URL canonicalization, unavailable fetch scores, Perplexity answer/source parsing, and evidence-reference validation. They are valuable but insufficient for production confidence.



16. Release plan

Phase	Objective	Exit criteria
Phase 0 — containment	Close security/privacy exposure and prevent synthetic data from reaching production-visible measured surfaces.	All P0 gates in sections 3.1, 12, and 15 pass.
Phase 1 — production foundation	Modular Flask app, /api/v1 contract, Alembic/FKs, RBAC, durable queue, Render topology, CI, observability, backups.	Staging matches production topology; recovery and migration rehearsals pass.
Phase 2 — Analytics GA	Harden crawl, asynchronous GSC, Perplexity evidence, metric contract, scheduling, export, accessibility, PWA update flow.	Analytics acceptance suite and SLO dashboards pass with controlled customers.
Phase 3 — unified intelligence	Migrate Prompt Intelligence and Visibility Tracking to shared evidence; make Master Workspace provenance-correct.	No production SHA/modelled metrics; comparable histories and evidence links pass.
Phase 4 — evidence-led content	Carry analytics opportunities into grounded content briefs, model-assisted drafting, versioning, review, and optional CMS connectors.	Draft provenance and human review are enforced; publication state is evidence-backed.
Phase 5 — scale	Agency organizations, roles, bulk workflows, alerts, provider expansion, quotas, cost controls, and performance tuning.	Tenant/load/security tests meet scale target and budget policy.

16.1 Rollout controls

- Use feature flags for provider connectors, scheduling, generated content, and beta modules.
- Start with internal/staging evidence, then a capped pilot with explicit source disclosures and spend limits.
- Backfill or migrate only after the new metric contract is stable; do not translate legacy synthetic scores into new evidence tables.
- Retain read-only legacy history only if it is visibly labelled modelled/demo and excluded from trends.
- Define rollback at application, migration, worker, and provider-feature levels before production enablement.



17. Risk register and open decisions

Risk	Impact	Mitigation / owner decision
Provider availability, price, or response drift	Missing/partial evidence, cost spikes, parse failure	Adapters, fixtures, circuit breakers, spend quotas, schema monitoring, source-specific degradation.
Synthetic legacy data misread as real	Loss of trust and incorrect business decisions	Disable in production, clear labels in demo, migrate modules onto shared evidence, exclude from aggregate trends.
Crawler abuse or DNS rebinding	Internal network access, service abuse, legal exposure	Pinned/egress-controlled networking, allowlists, crawl policy, quotas, audit logs, security tests.
OAuth/token compromise	Unauthorized Search Console access	Read-only scope, encryption, rotation, revoke/disconnect, least privilege, access logging, incident playbook.
Unbounded evidence retention	Privacy, cost, and data breach impact	Class-based retention, minimization, object storage, deletion/export tooling, customer controls.
Non-comparable trends	Misleading performance claims	Snapshot cohort/config, algorithm versioning, baseline breaks, no inferred delta.
Daemon-thread job loss	Incomplete scans and inconsistent state	Durable external queue, leases, idempotency, retries, cancellation, dead-letter handling.
Monolithic code/CSS regression	Slow change and inconsistent mobile UX	Modular services/components, design tokens, automated visual/E2E/accessibility tests.

17.1 Decisions required before GA

1. Select the durable queue/worker technology and managed hosting topology.
2. Approve organization/RBAC roles and the default signed-in destination.
3. Approve provider set, legal basis, quotas, budget ownership, and customer-facing source language.
4. Approve retention periods, account deletion SLA, audit-log retention, and data residency commitments.
5. Decide whether raw provider payloads remain in PostgreSQL or move to encrypted object storage.
6. Approve crawl user agent, robots policy, page limits, tenant quotas, and acceptable-use terms.
7. Approve Content Studio generation provider, model policy, human-review obligations, and publication semantics.
8. Set launch capacity targets and error-budget ownership for first-party services and external integrations.



18. Production acceptance checklist

Data truth

- ☐ No deterministic/modelled metric is presented as measured in production.
- ☐ Every metric shows source, time, status, denominator, and evidence link.
- ☐ Crawl, GSC, and provider metrics remain separated and use nullable unavailable states.

Security and privacy

- ☐ Sensitive repository paths are not web-accessible; runtime database is untracked and absent from the image.
- ☐ Contacts/admin are RBAC-protected, escaped, audited, and rate-limited.
- ☐ CSRF, SSRF/rebinding, authentication, secret, XSS, IDOR, header, and dependency gates pass.
- ☐ Retention, export, deletion, revoke, and privacy disclosures are operationally verified.

Architecture and operations

- ☐ Web, PostgreSQL, worker/queue, scheduler, backups, monitoring, and alerts are provisioned.
- ☐ Alembic migration and rollback rehearsal passes; no orphaned data exists.
- ☐ Jobs survive restarts, are idempotent, obey quota, and expose progress/failure/cancellation.
- ☐ RPO/RTO restore exercise and critical runbooks are signed off.

Product and quality

- ☐ Core journeys pass on desktop/mobile, supported browsers, keyboard, screen reader, reduced motion, and offline/update scenarios.
- ☐ Provider, metric, API, database, E2E, accessibility, load, and security suites pass in CI/staging.
- ☐ SLO dashboards are live and the release has named product, engineering, security, and operations approval.

Release authority

Production launch is approved only when every P0 item is closed, all P1 exceptions are explicit and time-bound, and named owners sign the production-readiness record.



Appendix A — Current API inventory

Domain	Current routes	Target action
System/public	GET /; static assets; GET /api/health; POST/GET /api/contacts	GET contacts must become admin-only; static catch-all must be removed.
Auth/account	POST /api/register; POST /api/login; POST /api/logout; GET /api/me	Add return path, verification, reset, roles, CSRF, rate limits, lifecycle.
Analytics projects	GET/POST /api/analytics/projects; DELETE project; GET report	Version, add update, pagination, idempotency, consistent source contract.
Website audits	POST project/audits; GET jobs/{id}; GET project/audit; legacy POST project/scan	Keep durable audit; deprecate legacy compatibility scan.
Google Search Console	OAuth start/callback; connection GET/DELETE; property PUT; sync POST	Add PKCE, revoke, durable paginated sync, idempotency, audit events.
Tracking config	GET tracking; topic/competitor/prompt CRUD; schedule PUT	Add pagination/update/version snapshot and role permissions.



Appendix A — Current API inventory (continued)

Domain	Current routes	Target action
Provider evidence	POST prompt-scans; GET evidence; GET evidence/{answer_id}	Add run pagination/filtering, cancellation, retention metadata, quotas.
Prompt Intelligence	Collection/query CRUD, analyze, report	Replace synthetic analysis with shared evidence service.
Visibility Tracking	Watchlist CRUD, scan, report	Replace synthetic scan with shared evidence service.
Content Studio	Document CRUD and generate	Add evidence handoff, provenance, version history, model/CMS adapters.
Master workspace	GET/POST /api/master-workspace; GET summary	Add explicit update/replace and source-correct aggregate read model.
Admin	GET /admin/contacts	Move behind admin RBAC and escaped template; audit access.



Appendix B — Logical data model

Domain	Current tables	Target note
Foundation	users, contacts, app_metadata	Account/contact/DB identity; add roles, orgs, sessions, consent, audit events.
Analytics compatibility	analytics_projects, analytics_runs, analytics_engine_metrics, analytics_prompts	Project remains; legacy metric tables require deprecation/migration.
Crawl	analytics_audit_jobs, analytics_site_audits, analytics_audit_pages, analytics_audit_findings, analytics_sitemaps	Evidence-backed multi-page audit and job state.
Search Console	gsc_connections, gsc_properties, gsc_sync_runs, gsc_query_rows	Encrypted OAuth, property choice, sync history, query/page rows.
Prompt evidence	analytics_topics, analytics_competitors, analytics_tracked_prompts, analytics_prompt_scan_runs, analytics_provider_answers, analytics_answer_sources, analytics_scan_schedules, analytics_content_opportunities	Primary production evidence model; add FK constraints, algorithm versions, cost/retry/retention metadata.
Prompt Intelligence	prompt_collections, prompt_queries, prompt_query_results	Replace synthetic results or migrate to shared evidence/read models.
Visibility	visibility_watchlists, visibility_scans, visibility_engine_results, visibility_mentions	Replace synthetic results or migrate to shared evidence/read models.
Content	content_documents	Add evidence links, generation metadata, version history, collaboration/publication records.
Master	master_workspaces	Link shared brand configuration to product views; avoid synthetic seeded measurements.

Current relationships are implemented in application code without database foreign keys. The target schema shall define tenant ownership, foreign keys, uniqueness, cascade/restrict behavior, and query-driven indexes through versioned migrations.



Appendix C — Environment variables

Group	Variables	Requirement note
Core	APP_ENV, SECRET_KEY, DATABASE_URL, DATABASE_INSTANCE_ID	Production requires managed secrets, stable DB binding, and identity check.
Crawler	AUDIT_MAX_PAGES, AUDIT_PAGE_BYTES, AUDIT_SITEMAP_BYTES, AUDIT_REQUEST_DELAY_SECONDS, AUDIT_USER_AGENT	Bound cost/size/rate and publish user-agent policy.
Perplexity	PERPLEXITY_API_KEY, PERPLEXITY_AGENT_PRESET, PERPLEXITY_AGENT_MAX_OUTPUT_TOKENS, PERPLEXITY_MAX_RESULTS, PERPLEXITY_SEARCH_CONTEXT, PERPLEXITY_MAX_PROMPTS_PER_SCAN, PERPLEXITY_REQUEST_DELAY_SECONDS	Secret server-side; budget, latency, region, and retry policy required.
Open model	HF_TOKEN, HF_BASE_URL, HF_MODEL, OLLAMA_BASE_URL, OLLAMA_MODEL	Used only for grounded actions; Ollama requires a reachable dedicated inference host.
Google	GOOGLE_CLIENT_ID, GOOGLE_CLIENT_SECRET, GOOGLE_OAUTH_REDIRECT_URI, OAUTH_TOKEN_ENCRYPTION_KEY, GSC_ROW_LIMIT	Stable encryption key, exact redirect, restricted clients, async pagination.
Jobs	ANALYTICS_JOB_BATCH, ANALYTICS_MAX_TRACKED_PROMPTS	Extend with queue URL, leases, concurrency, retry, dead-letter, quota, and scheduler timezone settings.
Security/ops	ALLOWED_HOSTS, TRUSTED_PROXY_COUNT, CSRF_SECRET, RATE_LIMIT_STORE, LOG_LEVEL, SENTRY/OTEL settings	Required target controls; names finalized in implementation.

Secret handling

Real credentials shall never be committed, embedded in browser JavaScript, printed in logs, or placed in the document. The .env.example file remains a non-secret contract only.



Appendix D — Glossary and source basis

Term	Definition
AEO	Answer Engine Optimization: improving the clarity, authority, and sourceability of content for answer systems.
GEO	Generative Engine Optimization: improving how a brand/content is represented and cited in generative discovery experiences.
Provider evidence	Saved original prompt result, answer, sources, request metadata, status, and timing from a supported provider API.
Technical readiness	A local heuristic derived from public website signals; not a provider visibility measurement.
Answer visibility	Percentage of completed provider answers that mention the tracked brand under the saved prompt cohort.



Appendix D — Glossary and source basis (continued)

Term	Definition
Citation	A provider answer annotation/source that links to the tracked domain.
Source presence	Whether the tracked domain appears in a provider's ranked source results for a measured prompt.
Share of voice	Tracked-brand presence relative to the tracked brand plus configured competitors for one saved cohort.
Cohort	The provider/model, prompt set, competitor snapshot, region, and algorithm version that define a comparable run.
Unavailable	A value was not measured due to missing configuration/evidence or failure; it is not equivalent to zero.



D.1 Audited source files

Source	Audit use
server_pg.py	Production endpoint, schema, APIs, crawls, integrations, jobs, legacy generators, account/admin flows.
analytics.html / analytics.js / analytics.css	Evidence-first Analytics workspace, source status, metrics, filters, export, responsive app shell.
index.html / script.js / styles.css / three-home.js	Marketing site, auth-aware header, master setup, contact, responsive behavior, illustrative chart/motion.
prompt_intelligence.* / visibility_tracking.* / content_studio.*	Dedicated product flows and current demo/template behavior.
workspace.* / profile.html	Combined workspace summary and account view.
manifest.webmanifest / sw.js / pwa.js / offline.html	PWA configuration, service worker, caching, and offline fallback.
render.yaml / Dockerfile / Procfile / requirements.txt / .env.example	Deployment, runtime, dependencies, and configuration contract.
AEO_ANALYTICS_SETUP.md	Integration setup and source-separation guidance.
tests/test_analytics_pipeline.py	Current five-test helper-level analytics safety/evidence suite.

D.2 Traceability convention

Requirement identifiers are stable by domain: FR for functional behavior, API for contracts, INT for external integrations, DATA for persistence/provenance, SEC/PRIV for protection, NFR for quality attributes, OPS for production operations, and TEST for verification. Implementation tickets and automated tests should reference these IDs.

Approval record

Role	Name	Decision	Date
Product owner		Approve / Reject	
Engineering lead		Approve / Reject	
Security / privacy		Approve / Reject	
Operations / SRE		Approve / Reject	

End of document

TRD-TRYSEARCH-001 • Version 1.0 • 13 August 2026